

# KRİPTOQRAFIYA KURSU

## Mühazirə 12

### Heş funksiyalarına giriş və xüsusiyyətləri

Bu mühazirə heş funksiyalarının əsas anlayışlarını, təhlükəsizlik xüsusiyyətlərini, quruluşlarını (Merkel-Damqord, süngər) və praktik tətbiqlərini əhatə edir.

July 31, 2026

## Contents

|           |                                                              |           |
|-----------|--------------------------------------------------------------|-----------|
| <b>1</b>  | <b>Mühazirənin Məqsədləri</b>                                | <b>2</b>  |
| <b>2</b>  | <b>Giriş</b>                                                 | <b>2</b>  |
| <b>3</b>  | <b>Heş funksiyalarının tərfi və əsas anlayışlar</b>          | <b>3</b>  |
| 3.1       | Heş Funksiyası Nədir?                                        | 3         |
| 3.2       | Heş funksiyalarının formal tərfi                             | 4         |
| 3.3       | Heş funksiyalarının tətbiq sahələri                          | 5         |
| <b>4</b>  | <b>Heş Funksiyalarının Təhlükəsizlik Xüsusiyyətləri</b>      | <b>5</b>  |
| 4.1       | Ön Görüntü Dayanıqlılığı (Preimage Resistance)               | 6         |
| 4.2       | İkinci Ön Görüntü Dayanıqlılığı (Second Preimage Resistance) | 6         |
| 4.3       | Toqquşma dayanıqlılığı (Collision resistance)                | 6         |
| 4.4       | Təhlükəsizlik Xüsusiyyətləri Arasında Əlaqələr               | 6         |
| <b>5</b>  | <b>Ad Günü Paradoksu və Toqquşma Hücumları</b>               | <b>7</b>  |
| 5.1       | Ad Günü Paradoksunun Riyazi Əsasları                         | 7         |
| 5.2       | Heş Funksiyalarında Toqquşma Ehtimalı                        | 8         |
| 5.3       | Ad Günü Hücumu (Birthday Attack)                             | 8         |
| <b>6</b>  | <b>Merkel-Damqord Quruluşu</b>                               | <b>9</b>  |
| 6.1       | Merkel-Damqord Konstruksiyasının İş Prinsipi                 | 9         |
| 6.2       | Doldurma (Padding) Qaydaları                                 | 10        |
| 6.3       | Sıxışdırma Funksiyası (Compression Function)                 | 10        |
| 6.4       | Merkel-Damqord Quruluşunun Təhlükəsizlik Sübutu              | 11        |
| 6.5       | Uzunluq Genişləndirmə Hücumu (Length Extension Attack)       | 11        |
| <b>7</b>  | <b>Süngər (Sponge) Quruluşu</b>                              | <b>12</b> |
| 7.1       | Süngər Konstruksiyasının İş Prinsipi                         | 12        |
| 7.2       | Süngər Quruluşunun Parametrləri                              | 12        |
| 7.3       | Udma (Absorbing) Mərhələsi                                   | 13        |
| 7.4       | Sıxma (Squeezing) Mərhələsi                                  | 13        |
| 7.5       | Merkel-Damqord və Süngər Quruluşlarının Müqayisəsi           | 13        |
| <b>8</b>  | <b>Heş Funksiyalarının Praktiki Tətbiqləri</b>               | <b>14</b> |
| 8.1       | Parolların Təhlükəsiz Saxlanması                             | 14        |
| 8.2       | Məlumat Bütövlüyünün Yoxlanması (Data Integrity)             | 14        |
| 8.3       | Rəqəmsal İmzalar                                             | 15        |
| 8.4       | Merkle Ağacları və Blokçeyn Texnologiyası                    | 15        |
| 8.5       | Açar Törətmə Funksiyaları (KDF)                              | 16        |
| 8.6       | HMAC və Mesaj Autentifikasiyası                              | 16        |
| <b>9</b>  | <b>Nümunə Məsələlər və Çalışmalar</b>                        | <b>17</b> |
| <b>10</b> | <b>Çalışmaların Həlli</b>                                    | <b>18</b> |
| <b>11</b> | <b>Xülasə</b>                                                | <b>18</b> |

# 1 Mühazirənin Məqsədləri

Bu mühazirəni bitirdikdən sonra tələbə aşağıdakı bilik və bacarıqlara sahib olacaq:

- **Heş Funksiyalarının Mahiyyəti:** Kriptoqrafik heş funksiyalarının texniki tərifini və onların əsas xüsusiyyətlərini (deterministik olması, sürətli hesablanması) izah edə biləcək (Stinson and Paterson, 2018).
- **Təhlükəsizlik Xüsusiyyətləri:** Ön görüntü dayanıqlılığı (pre-image resistance), ikinci ön görüntü dayanıqlılığı və toqquşma dayanıqlılığı (collision resistance) anlayışlarını və onların bir-birindən fərqlini başa düşəcək (Katz and Lindell, 2020).
- **Kriptoanalitik Hücumlar:** Ad günü paradoksu (birthday paradox) və toqquşma hücumlarının riyazi əsaslarını dərk edərək, heş dəyərinin uzunluğuna görə hücum ehtimallarını hesablaya biləcək (Stinson and Paterson, 2018).
- **Daxili Struktur (Quruluş):** Merkl-Damqord (Merkle-Damgård) iterativ quruluşunun və SHA-3-də istifadə olunan süngər (sponge) strukturunun iş prinsiplərini fərqləndirə biləcək (Damgård, 1989; Merkle, 1989).
- **Praktik Tətbiq Sahələri:** Heş funksiyalarının real dünyadakı tətbiqlərini (parolların təhlükəsiz saxlanması, məlumat bütövlüyü, rəqəmsal imzalar və blokçeyn texnologiyası) dərinlən dərk edəcək (Ferguson et al., 2010).
- **Hücum Davamlılığı:** Uzunluq genişləndirmə hücumunun (length extension attack) mahiyyətini, hansı strukturlarda bu problemin yarandığını və onun qarşısını alma üsullarını biləcək (Katz and Lindell, 2020).

## Mövzunun Önəmi

Heş funksiyaları müasir kriptoqrafiyanın "işçi atları" hesab olunur. Onlar məlumatın bütövlüyünü təmin edən fundamental alətlərdir və aşağıdakı sistemlərin qurulmasında əvəzedilməz rol oynayırlar:

- **Rəqəmsal imzalar:** Böyük həcmli sənədlərin sürətli və təhlükəsiz imzalanması üçün.
- **Blokçeyn texnologiyası:** Blokların zəncirvari bağlanması və tranzaksiyaların dəyişməzliyinin təmin edilməsi üçün.
- **Təhlükəsiz autentifikasiya:** İstifadəçi parollarının verilənlər bazasında birbaşa deyil, "barmaq izi" şəklində saxlanması üçün.

Bu funksiyalar olmadan müasir internet təhlükəsizliyi və rəqəmsal etibar mexanizmlərini təsvir etmək mümkün deyil.

## 2 Giriş

İnformasiya texnologiyalarının sürətli inkişafı ilə birlikdə, məlumatların təhlükəsizliyi və bütövlüyünün qorunması problemi getdikcə daha aktuallaşır. İnternet üzərindən ötürülən məlumatların dəy-

işdirilməməsi, saxtalaşdırılmaması və ya icazəsiz girişlərdən qorunması üçün müxtəlif kriptografik üsullardan istifadə olunur. Bu üsullar arasında **heş funksiyaları (hash functions)** xüsusi yer tutur.

Heş funksiyaları müasir kriptografiyanın təməl daşlarından biridir. Onlar ixtiyari uzunluqlu məlumatı sabit uzunluqlu qısa bir dəyərə (heş) çevirən birtərəfli funksiyalardır. Bu funksiyalar sayəsində böyük həcmli məlumatların bütövlüyü yoxlanıla bilər, parollar təhlükəsiz saxlanılır, rəqəmsal imzalar yaradılır və blokçeyn texnologiyasının əsasını təşkil edir.

#### Mövzunun Önəmi

Heş funksiyaları müasir kriptografiyanın "işçi atlarıdır". Onlar olmadan rəqəmsal imzalar, blokçeyn və ya təhlükəsiz autentifikasiya sistemlərini qurmaq mümkün deyil.

Bu müəhazirədə heş funksiyalarının əsas anlayışları, təhlükəsizlik xüsusiyyətləri, quruluşları və praktik tətbiqləri ətraflı şəkildə öyrəniləcəkdir.

#### Müzakirə Olunacaq Əsas Suallar

- **Birtərəflilik:** Heş funksiyası nədir və niyə "birtərəfli" (one-way) funksiya adlanır?
- **Təhlükəsizlik Meyarları:** Heş funksiyalarının təhlükəsizliyi hansı xüsusiyyətlərlə (dayanıqlılıq növləri) ölçülür?
- **Kriptoanaliz:** Ad günü paradoksu heş funksiyalarına və toqquşma ehtimalına necə təsir edir?
- **Daxili Struktur:** Merkl-Damqord və süngər (sponge) quruluşları arasında hansı fundamental fərqlər var?
- **Praktika:** Heş funksiyaları gündəlik həyatda və müasir protokollarda harada istifadə olunur?

## 3 Heş funksiyalarının tərfi və əsas anlayışlar

### 3.1 Heş Funksiyası Nədir?

**Heş funksiyası (hash function)** — ixtiyari uzunluqlu giriş məlumatını (mesajı) sabit uzunluqlu çıxışa (heş dəyərinə) çevirən riyazi alqoritmədir (Stinson and Paterson, 2018). Bu çevrilmə prosesi **birtərəfli** (one-way) xarakter daşıyır; yəni heş dəyərindən istifadə edərək orijinal mesajı bərpa etmək müasir hesablama gücləri ilə mümkün deyil.

Heş funksiyaları gündəlik həyatda tez-tez rast gəlinən anlayışlarla analogiya təşkil edir. Məsələn, bir insanın **barmaq izi** onun şəxsiyyətini unikal şəkildə təmsil edən qısa bir identifikatordur. Eyni şəkildə, heş funksiyaları da böyük həcmli rəqəmsal məlumatları qısa və unikal "rəqəmsal barmaq izlərinə" çevirir.

**Tərif 3.1.** *Heş Funksiyası.* Heş funksiyası  $H : \{0, 1\}^* \rightarrow \{0, 1\}^n$  şəklində təyin olunan, ixtiyari uzunluqlu ikilik (binary) sətirləri  $n$ -bit uzunluqlu sabit ölçülü çıxışa xəritələyən funksiyadır (Paar and Pelzl, 2010).

Bu riyazi tərifin komponentləri aşağıdakıları ifadə edir:

- $\{0, 1\}^*$ : Giriş çoxluğu — istənilən uzunluqlu (boş sətir də daxil olmaqla) bütün mümkün ikilik sətirlər.
- $\{0, 1\}^n$ : Çıxış çoxluğu — dəqiq  $n$ -bit uzunluqlu ikilik sətirlər çoxluğu.
- $n$ : Heş funksiyasının çıxış uzunluğu (məsələn, **SHA-256** üçün  $n = 256$ , **MD5** üçün  $n = 128$ ).

#### Deterministik Xüsusiyyət

Heş funksiyaları deterministiktir: eyni giriş məlumatı hər zaman, istisnasız olaraq eyni heş çıxışını verməlidir. Girişdəki hətta bir bitlik dəyişiklik ("lavina (avalanche) effekti" - avalanche effect) tamamilə fərqli bir heş dəyərinin yaranmasına səbəb olur.

### 3.2 Heş funksiyalarının formal tərif

Kriptografik heş funksiyaları təhlükəsizliyi təmin etmək üçün aşağıdakı fundamental xüsusiyyətlərə malik olmalıdır (Katz and Lindell, 2020):

1. **Deterministik:** Funksiya eyni giriş məlumatı üçün hər zaman istisnasız olaraq eyni çıxış (heş) dəyərini istehsal edir.
2. **Sürətli Hesablama:** İxtiyari uzunluqlu giriş məlumatı üçün heş dəyərinin hesablanması səmərəli və sürətli şəkildə həyata keçirilməlidir.
3. **Ön Görüntü Dayanıqlılığı (Preimage Resistance):** Verilmiş bir  $y = H(x)$  heş dəyəri üçün orijinal  $x$  girişini tapmaq hesablama baxımından qeyri-mümkün (çətin) olmalıdır. Bu xüsusiyyət funksiyanın "birtərəfli" olduğunu təmin edir.
4. **İkinci Ön Görüntü Dayanıqlılığı (Second Preimage Resistance):** Verilmiş bir  $x_1$  girişi üçün  $H(x_1) = H(x_2)$  və  $x_1 \neq x_2$  şərtlərini ödəyən fərqli bir  $x_2$  girişi tapmaq hesablama baxımından mürəkkəb olmalıdır.
5. **Toqquşma Dayanıqlılığı (Collision Resistance):**  $H(x_1) = H(x_2)$  və  $x_1 \neq x_2$  şərtini ödəyən hər hansı iki fərqli giriş cütliyünü tapmaq hesablama baxımından qeyri-mümkün olmalıdır.
6. **Lavina Effekti (Avalanche Effect):** Giriş məlumatında edilən kiçik bir dəyişiklik (məsələn, bir bitin dəyişdirilməsi) çıxışdakı heş dəyərinin əhəmiyyətli dərəcədə və tamamilə fərqli görünməsinə səbəb olmalıdır.

**Nümunə 3.1** (Lavina Effekti Nümunəsi). *SHA-256 heş funksiyası vasitəsilə bir-birinə çox yaxın olan iki mətnin çıxış dəyərlərini müqayisə edək:*

**Mətn 1:** "Kriptografiya kursu"

**SHA-256:** 3805f9006ca8924f22381255b5a18a33e72f10b6f520a95010f3fcfa7e56691

**Mətn 2:** "Kriptografiya kursu." (Sona nöqtə əlavə olunub)

**SHA-256:** 572f6ee739aea68aac3f20136de8da9b335669762d3c046fa932c595917b9a

Göründüyü kimi, girişdə cəmi bir simvolun dəyişməsi heş dəyərinin tamamilə fərqli görünməsinə səbəb olur.

### 3.3 Heş funksiyalarının tətbiq sahələri

Heş funksiyaları müasir informasiya texnologiyalarında çox geniş tətbiq sahələrinə malikdir (Ferguson et al., 2010):

1. **Parol Saxlanması:** Təhlükəsizlik baxımından istifadəçi parolları verilənlər bazasında açıq şəkildə deyil, heş formasında saxlanılır. Autentifikasiya zamanı daxil edilən parol heşlənir və nəticə saxlanılan heşlə müqayisə edilir (Stinson and Paterson, 2018).
2. **Məlumat Bütövlüyünün Yoxlanması:** Faylın və ya mesajın ötürülmə zamanı dəyişdirilmədiyini yoxlamaq üçün onun heş dəyəri ("checksum") saxlanılır və qəbul edildikdə yenidən hesablanaraq orijinalı ilə müqayisə edilir.
3. **Rəqəmsal İmzalar:** Böyük həcmli məlumatların birbaşa imzalanması səmərəli olmadığından, əvvəlcə məlumatın heşi hesablanır, sonra isə bu qısa heş dəyəri imzalanır (Katz and Lindell, 2020).
4. **Merkle Ağaçları (Merkle Trees):** Blokçeyn texnologiyasında çoxlu sayda əməliyyatın bütövlüyünü tək bir "kök heş" (root hash) vasitəsilə səmərəli şəkildə təmin etmək üçün istifadə olunur (Antonopoulos, 2017).
5. **HMAC (Heşə əsaslanan məlumat autentikasiya kodu - Hash-based Message Authentication Code):** Mesajın həm tamlığını, həm də mənbəyini yoxlamaq məqsədilə gizli açar və heş funksiyası əsasında qurulan mexanizmdir (Stinson and Paterson, 2018).
6. **Açar Törətmə Funksiyaları (KDF):** Zəif parollardan və ya digər ilkin materiallardan kriptografik cəhətdən güclü açarlar yaratmaq üçün istifadə olunur.

## 4 Heş Funksiyalarının Təhlükəsizlik Xüsusiyyətləri

Heş funksiyalarının təhlükəsizlik səviyyəsi üç fundamental dayanıqlılıq xüsusiyyəti ilə xarakterizə olunur (Katz and Lindell, 2020):

- **Ön Görüntü Dayanıqlılığı (Pre-image Resistance):** Verilmiş bir  $y$  heş dəyəri üçün  $H(x) = y$  şərtini ödəyən hər hansı bir  $x$  girişini tapmaq hesablama baxımından qeyri-mümkün olmalıdır. Bu xüsusiyyət funksiyanın "birtərəfli" (one-way) olmasını təmin edir.
- **İkinci Ön Görüntü Dayanıqlılığı (Second Pre-image Resistance):** Verilmiş konkret bir  $x$  girişi üçün  $H(x) = H(x')$  və  $x \neq x'$  şərtlərini ödəyən başqa bir  $x'$  girişini tapmaq hesablama baxımından çətin olmalıdır. Bu xüsusiyyət mövcud olan bir mesajın (məsələn, rəqəmsal imzalı sənədin) heş dəyərini dəyişmədən məzmununun saxtalaşdırılmasının qarşısını alır.
- **Toqquşma Dayanıqlılığı (Collision Resistance):**  $H(x_1) = H(x_2)$  və  $x_1 \neq x_2$  şərtini ödəyən hər hansı iki fərqli  $x_1$  və  $x_2$  giriş cütliyünü tapmaq hesablama baxımından qeyri-mümkün olmalıdır. Bu, ən güclü dayanıqlılıq tələbi hesab olunur.

Toqquşma dayanıqlılığı (Collision Resistance) hər zaman İkinci Ön Görüntü dayanıqlılığını təmin edir, lakin bunun əksi hər zaman doğru deyil. Kriptografik analizlərdə toqquşma tapmaq çox vaxt "Ad günü paradoksu" (Birthday Paradox) prinsipinə əsaslanır.

### 4.1 Ön Görüntü Dayanıqlılığı (Preimage Resistance)

**Tərif 4.1.** *Ön Görüntü Dayanıqlılığı*  $y$  heş dəyəri verildikdə,  $H(x) = y$  şərtini ödəyən hər hansı bir  $x$  girişini tapmaq hesablama baxımından çətin olmalıdır (Stinson and Paterson, 2018).

Bu xüsusiyyət heş funksiyasının **birtərəfli** (one-way) olmasını təmin edir. Başqa sözlə, heş dəyərindən istifadə edərək orijinal məlumatı bərpa etmək mümkün olmamalıdır. İdeal halda,  $n$ -bitlik çıxışa malik heş funksiyası üçün ön görüntü tapmaq mürəkkəbliyi  $2^n$  əməliyyat tərtibində olmalıdır.

**Nümunə 4.1** (Ön Görüntü Dayanıqlılığı). *Tutaq ki,  $H(x) = 0x3F2A...$  heş dəyəri verilib. Bu heş dəyərini yaradan  $x$  girişini tapmaq üçün orta hesabla  $2^n$  sınaq tələb olunur. **SHA-256** üçün bu,  $2^{256} \approx 10^{77}$  sınaq deməkdir ki, bu da müasir superkompüterlər üçün belə praktik olaraq qeyri-mümkündür.*

### 4.2 İkinci Ön Görüntü Dayanıqlılığı (Second Preimage Resistance)

**Tərif 4.2.** *İkinci Ön Görüntü Dayanıqlılığı* Konkret bir  $x_1$  girişi verildikdə,  $H(x_1) = H(x_2)$  və  $x_1 \neq x_2$  şərtini ödəyən fərqli bir  $x_2$  girişini tapmaq hesablama baxımından çətin olmalıdır (Stinson and Paterson, 2018).

Bu xüsusiyyət, mövcud olan bir mesajla eyni heş dəyərində (barmaq izində) malik başqa bir alternativ mesaj tapmağın qarşısını alır. İkinci ön görüntü dayanıqlılığı üçün tələb olunan hesablama mürəkkəbliyi də  $2^n$  səviyyəsindədir.

**Nümunə 4.2** (İkinci Ön Görüntü Dayanıqlılığı). *Tutaq ki, rəqəmsal imzalanmış bir  $Müqavilə.txt$  faylı var və onun heş dəyəri sistemdə qeyd olunub. Hücümçü bu faylla eyni heş dəyərində malik olan, lakin şərtləri fərqli (məsələn, ödəniş məbləği dəyişdirilmiş)  $Müqavilə_saxta.txt$  faylı yaratmağa çalışır. İkinci ön görüntü dayanıqlılığı sayəsində bu cür saxtalaşdırma cəhdlərinin qarşısı alınır.*

### 4.3 Toqquşma dayanıqlılığı (Collision resistance)

**Tərif 4.3** (Toqquşma dayanıqlılığı).  $H(x_1) = H(x_2)$  və  $x_1 \neq x_2$  şərtini ödəyən iki fərqli  $x_1, x_2$  girişi tapmaq hesablama baxımından çətin olmalıdır (Katz and Lindell, 2020).

Bu, heş funksiyalarının ən güclü təhlükəsizlik xüsusiyyətidir. Toqquşma tapmaq, rəqəmsal imzaların saxtalaşdırılmasına və məlumat bütövlüyünün pozulmasına səbəb ola bilər. Ad günü paradoksuna görə, toqquşma tapmaq üçün tələb olunan mürəkkəblik  $2^{n/2}$ -dir.

**Nümunə 4.3** (Toqquşma dayanıqlılığı). *MD5 heş funksiyası üçün 2004-cü ildən etibarən praktik toqquşmalar göstərilmişdir (Wang and Yu, 2005). Bu o deməkdir ki, eyni MD5 dəyərində malik iki fərqli mesaj qurmaq mümkündür. Buna görə MD5 toqquşmaya dayanıqlıq tələb olunan tətbiqlər üçün artıq təhlükəsiz hesab edilmir.*

### 4.4 Təhlükəsizlik Xüsusiyyətləri Arasında Əlaqələr

Heş funksiyalarının üç əsas təhlükəsizlik meyarı bir-birindən asılı deyil və onlar arasında müəyyən iyerarxik əlaqələr mövcuddur (Katz and Lindell, 2020):

**Teorem 4.1.** *[Təhlükəsizlik Xüsusiyyətlərinin İyerarxiyası] Heş funksiyaları üçün aşağıdakı məntiqi əlaqələr doğrudur:*

1. *Toqquşma dayanıqlılığı*  $\Rightarrow$  *İkinci ön görüntü dayanıqlılığı*
2. *İkinci ön görüntü dayanıqlılığı*  $\nRightarrow$  *Toqquşma dayanıqlılığı*
3. *İkinci ön görüntü dayanıqlılığı*  $\nRightarrow$  *Ön görüntü dayanıqlılığı*

*Proof.* Toqquşma dayanıqlılığı hər hansı iki girişi tapmağın çətinliyini tələb etdiyi üçün, o, avtomatik olaraq konkret bir girişə qarşı ikinci birini tapmağı da (ikinci ön görüntü) çətinləşdirir. Lakin əksi doğru deyil; funksiya konkret bir  $x$  üçün alternativ tapmağa imkan verməsə də, hücumçuya hər hansı iki ixtiyari  $x_1, x_2$  cütünü tapmaq şansı yarada bilər (məsələn, ad günü paradoksu vasitəsilə).  $\square$

| Xüsusiyyət                             | Tərif (Məqsəd)                                        | Mürəkkəblilik | Əhəmiyyəti            |
|----------------------------------------|-------------------------------------------------------|---------------|-----------------------|
| <b>Ön görüntü dayanıqlılığı</b>        | $y$ verildikdə, $H(x) = y$ olan $x$ tapmaq            | $2^n$         | Birtərəflilik         |
| <b>İkinci ön görüntü dayanıqlılığı</b> | $x_1$ verildikdə, $H(x_1) = H(x_2)$ olan $x_2$ tapmaq | $2^n$         | Saxtalaşdırmaya qarşı |
| <b>Toqquşma dayanıqlılığı</b>          | $H(x_1) = H(x_2)$ olan ixtiyari $x_1, x_2$ tapmaq     | $2^{n/2}$     | Rəqəmsal imzalar      |

Table 1: Heş funksiyalarının təhlükəsizlik xüsusiyyətlərinin müqayisəli təhlili

#### Mürəkkəblilik fərqi

Diqqət yetirin ki, toqquşma dayanıqlılığı üçün hücum mürəkkəbliyi digərlərindən xeyli aşağıdır ( $2^{n/2}$ ). Bu fərq "Ad günü paradoksu" ilə əlaqədardır və heş funksiyalarının çıxış uzunluğunun seçilməsində (məsələn, 128 bitlik MD5-in artıq təhlükəsiz sayılmaması) həlledici rol oynayır.

## 5 Ad Günü Paradoksu və Toqquşma Hücumları

### 5.1 Ad Günü Paradoksunun Riyazi Əsasları

Ad günü paradoksu ehtimal nəzəriyyəsinin ən məşhur və intuitiv olaraq gözlənilməz nümunələrindən biridir. Bu fenomen heş funksiyalarının toqquşma dayanıqlılığının analizində mühüm rol oynayır (Stinson and Paterson, 2018).

**Teorem 5.1.** *Ad Günü Paradoksu  $N$  mümkün dəyər arasından  $q$  sayda element təsadüfi və asılı olmayaraq seçildikdə, ən azı iki elementin eyni olma (toqquşma) ehtimalı aşağıdakı düsturla yaxınlaşdırılır (Stinson and Paterson, 2018):*

$$P(\text{toqquşma}) \approx 1 - e^{-\frac{q^2}{2N}}$$

Bu ehtimalın 0.5 (yəni 50%) səviyyəsinə çatması üçün tələb olunan seçim sayı ( $q$ ) aşağıdakı kimidir:

$$q \approx \sqrt{2N \ln 2} \approx 1.177\sqrt{N}$$

Kriptografik heş funksiyaları üçün  $N = 2^n$  (burada  $n$  çıxış bitlərinin sayıdır). Bu halda 50% ehtimalla toqquşma tapmaq üçün lazım olan sınaq sayı:

$$q \approx 1.177 \cdot 2^{n/2}$$

**Nümunə 5.1** (Ad Günü Paradoksu Nümunələri). *İlin 365 gündən ibarət olduğunu fərz etsək ( $N = 365$ ):*

- **23 nəfərlik** qrupda ən azı iki nəfərin eyni ad gününə sahib olma ehtimalı  $> 0.5$  təşkil edir.
- **57 nəfərlik** qrupda bu ehtimal  $> 0.99$  səviyyəsinə qalxır.
- **70 nəfərlik** qrupda isə ehtimal  $> 0.999$  olur.

## 5.2 Heş Funksiyalarında Toqquşma Ehtimalı

Heş funksiyalarında  $q$  sayda təsadüfi giriş üçün toqquşma ehtimalı çıxış uzunluğu  $n$  olmaqla belə hesablanır (Stinson and Paterson, 2018):

$$P_{\text{toqquşma}} \approx 1 - e^{-\frac{q^2}{2 \cdot 2^n}}$$

| Seçim sayı ( $q$ ) | $n = 128$ (MD5)                | $n = 160$ (SHA-1)              | $n = 256$ (SHA-256)            |
|--------------------|--------------------------------|--------------------------------|--------------------------------|
| $2^{n/4}$          | $2^{32}$ sınaq                 | $2^{40}$ sınaq                 | $2^{64}$ sınaq                 |
| <b>Ehtimal</b>     | $\approx 2.71 \times 10^{-20}$ | $\approx 4.14 \times 10^{-25}$ | $\approx 1.47 \times 10^{-39}$ |
| $2^{n/2}$          | $2^{64}$ sınaq                 | $2^{80}$ sınaq                 | $2^{128}$ sınaq                |
| <b>Ehtimal</b>     | $\approx \mathbf{0.393}$       | $\approx \mathbf{0.393}$       | $\approx \mathbf{0.393}$       |
| $2^{n/2+1}$        | $2^{65}$ sınaq                 | $2^{81}$ sınaq                 | $2^{129}$ sınaq                |
| <b>Ehtimal</b>     | $\approx 0.865$                | $\approx 0.865$                | $\approx 0.865$                |

Table 2: Müxtəlif heş funksiyalarında toqquşma ehtimalının müqayisəsi

Cədvəldən göründüyü kimi,  $2^{n/2}$  sınaq aparıldıqda toqquşma ehtimalı giriş sayından asılı olmayaraq sabit qalır. Bu səbəbdən, 128 bitlik təhlükəsizlik səviyyəsi təmin etmək üçün heş funksiyasının çıxışı ən azı **256 bit** olmalıdır.

## 5.3 Ad Günü Hücumu (Birthday Attack)

Ad günü hücumu, ad günü paradoksunun ehtimal prinsiplərinə əsaslanaraq heş funksiyalarında toqquşma (collision) tapmaq üçün istifadə edilən ümumi (generic) bir üsuldur. Bu hücumun ən mühüm cəhəti onun mürəkkəbliyinin  $2^{n/2}$  olmasıdır — bu, tam axtarış (brute-force,  $2^n$ ) metodu-ndan qat-qat daha səmərəlidir.

**Nümunə 5.2.** *Ad Güünü Hücumu üzrə Müqayisələr Müxtəlif heş alqoritmləri üçün toqquşma tapmağın nəzəri və praktik sərhədləri aşağıdakı kimidir:*

- **MD5 (128-bit):** *İdeal ümumi ad günü hücumu üçün nəzəri sərhəd  $2^{64}$  əməliyyatdır. Lakin MD5 alqoritminin daxili strukturundakı zəifliklər səbəbindən praktik xüsusi toqquşma hücumları bu həddən xeyli daha az resurs tələb edir.*
- **SHA-1 (160-bit):** *Nəzəri toqquşma sərhədi  $2^{80}$  əməliyyatdır. 2017-ci ildə həyata keçirilən SHAttered layihəsi çərçivəsində ilk real SHA-1 toqquşması nümayiş etdirilmişdir.*
- **SHA-256 (256-bit):** *Bu funksiya üçün ad günü hücumunun mürəkkəbliyi  $2^{128}$  təşkil edir. Müasir hesablama texnologiyaları ilə bu sayda sınaq aparmaq hazırda praktik olaraq qeyri-mümkün hesab olunur.*

### Nəticə

Toqquşma dayanıqlılığını təmin etmək üçün heş funksiyasının çıxış uzunluğu ( $n$ ), hədəflənən təhlükəsizlik səviyyəsindən ən azı iki dəfə böyük seçilməlidir.

## 6 Merkl-Damqord Quruluşu

### 6.1 Merkl-Damqord Konstruksiyasının İş Prinsipi

Merkel-Damqord quruluşu MD5, SHA-1 və SHA-2 kimi klassik heş funksiyalarının fundamental memarlıq modelidir (Damgård, 1989; Merkle, 1989). Bu konstruksiyanın əsas məqsədi ixtiyari uzunluqlu mesajı sabit uzunluqlu çıxışa (heş dəyərinə) çevirmək üçün məlumatı bərabər ölçülü bloklara bölərək ardıcıl emal etməkdir.

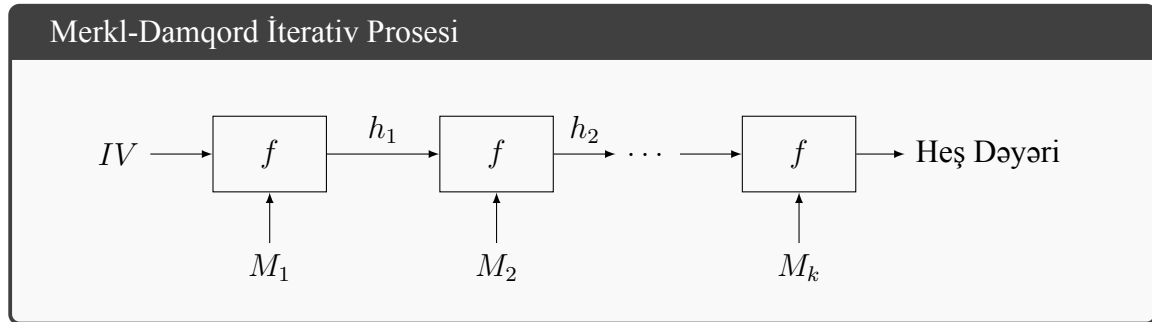


Figure 1: Merkl-Damqord quruluşunun sxematik təsviri

Merkel-Damqord konstruksiyasının üç əsas komponenti mövcuddur (Damgård, 1989):

- **İlkin Dəyər (IV - Initial Value):** Alqoritm tərəfindən əvvəlcədən təyin edilmiş, sabit  $n$ -bitlik başlanğıc vektoru.
- **Sıxışdırma Funksiyası (Compression Function):**  $f : \{0, 1\}^n \times \{0, 1\}^r \rightarrow \{0, 1\}^n$  — cari aralıq heş dəyəri ( $h_{i-1}$ ) və növbəti mesaj blokunu ( $M_i$ ) giriş kimi qəbul edib, yeni aralıq heş dəyərini ( $h_i$ ) hasil edən nüvə funksiya.
- **Doldurma Qaydası (Padding):** Mesajın ümumi uzunluğunu blok ölçüsünə ( $r$  bit) tam bölünən hala gətirmək üçün sonuncu bloka əlavə edilən xüsusi bitlər ardıcılığı.

**Tərif 6.1.** *Merkel-Damqord İterasiyası* Merkel-Damqord quruluşunda heşləmə prosesi aşağıdakı rekursiv tənliklərlə ifadə olunur (Damgård, 1989):

$$\begin{cases} h_0 = IV \\ h_i = f(h_{i-1}, M_i) & \text{üçün } i = 1, \dots, k \\ H(M) = h_k \end{cases}$$

Burada  $M_1, M_2, \dots, M_k$  mesajın  $r$ -bitlik bloklarını təmsil edir.

## 6.2 Doldurma (Padding) Qaydaları

Merkel-Damqord quruluşunda mesajın ümumi uzunluğu blok ölçüsünə ( $r$  bit) tam bölünmədikdə, prosesin düzgün davam etməsi üçün **doldurma (padding)** tətbiq olunur (Stinson and Paterson, 2018). Standart kriptografik doldurma prosesi aşağıdakı kimidir:

1. Mesajın dərhal sonuna "1" biti əlavə edilir.
2. Blokun dolması üçün lazım olan qədər (sonuncu hissə istisna olmaqla) "0" bitləri əlavə edilir.
3. Mesajın orijinal uzunluğu (bitlərlə) sonuncu blokun xüsusi ayrılmış hissəsində (adətən son 64 və ya 128 bit) saxlanılır.

**Nümunə 6.1** (MD5 üçün Doldurma Mexanizmi). *MD5 alqoritmində mesaj blokları 512 bit (64 bayt) təşkil edir. Doldurma prosesi belədir:*

- Mesajın sonuna  $0x80$  baytı ( $10000000_2$ ) əlavə edilir.
- Blokun uzunluğu 448 bitə (56 bayt) çatana qədər  $0x00$  baytları ilə doldurulur.
- Qalan son 64 bitə orijinal mesajın uzunluğu əlavə edilərək blok 512 bitə tamamlanır.

## 6.3 Sıxışdırma Funksiyası (Compression Function)

Sıxışdırma funksiyası Merkel-Damqord konstruksiyasının nüvəsini və ən mühüm komponentini təşkil edir (Damgård, 1989). Bu funksiya iki əsas girişi qəbul edərək sabit uzunluqlu çıxış hasil edir:

- $h_{i-1}$ : Əvvəlki iterasiyadan əldə edilən aralıq heş dəyəri ( $n$  bit).
- $M_i$ : Cari mesaj bloku ( $r$  bit).

Funksiyanın çıxışı növbəti addım üçün giriş rolu oynayan yeni  $n$ -bitlik aralıq dəyərdir.

**Teorem 6.1.** *Sıxışdırma Funksiyasının Təhlükəsizliyi.* Əgər istifadə olunan  $f$  sıxışdırma funksiyası toqquşmaya dayanıqlıdırsa (collision resistant), onda Merkel-Damqord konstruksiyası əsasında qurulan ümumi  $H$  heş funksiyası da toqquşmaya dayanıqlıdır (Damgård, 1989).

*İsbatın mahiyyəti.* Bu teorem göstərir ki, mürəkkəb bir heş funksiyasının təhlükəsizliyi onun təməlində duran daha kiçik komponentin — sıxışdırma funksiyasının təhlükəsizliyinə endirilə bilər. Əgər hücumçu  $H$  funksiyasında toqquşma tapa bilirsə, bu, riyazi olaraq onun  $f$  funksiyasında da toqquşma tapdığı mənasına gəlir.  $\square$

## 6.4 Merkl-Damqord Quruluşunun Təhlükəsizlik Sübutu

Dördüncü nəsil kriptografiyanın əsasını qoyan Damqord (Damgård, 1989) və Merkl (Merkle, 1989) müstəqil olaraq sübut etmişlər ki, heş funksiyasının tam təhlükəsizliyi onun təməlində duran sıxışdırma funksiyasının (compression function) toqquşmaya dayanıqlılığına endirilə bilər.

*Sübutun İdeyası.* Tutaq ki,  $H(M) = H(M')$  və  $M \neq M'$  şərtini ödəyən iki fərqli mesaj (toqquşma) tapılıb. Bu halda iki ssenari mümkündür:

1.  $\text{len}(M) \neq \text{len}(M')$ : Mesajların uzunluqları fərqlidir. Doldurma (padding) qaydasına görə sonuncu bloklara fərqli uzunluq məlumatı daxil edildiyi üçün, sıxışdırma funksiyasının son addımında mütləq toqquşma baş verir.
2.  $\text{len}(M) = \text{len}(M')$ : Mesajların uzunluqları eynidir. Bu halda sonuncu blokdan ( $k$ -cı blok) başlayaraq geriye doğru ( $k-1, k-2, \dots$ ) zəncirvari şəkildə yoxlama apardıqda, mesajların fərqləndiyi ilk nöqtədə sıxışdırma funksiyasında toqquşma tapılacaqdır.

Hər iki hal göstərir ki,  $H$  funksiyasında toqquşma tapmaq,  $f$  sıxışdırma funksiyasında toqquşma tapmağı tələb edir.  $\square$

## 6.5 Uzunluq Genişləndirmə Hücumu (Length Extension Attack)

Merkel-Damqord konstruksiyasının ən ciddi zəifliyi onun **uzunluq genişləndirmə hücumuna** qarşı həssaslığıdır (Katz and Lindell, 2020). Bu zəiflik MD5, SHA-1 və SHA-2 kimi bir çox klassik heş funksiyalarına təsir edir.

**Tərif 6.2.** *Uzunluq Genişləndirmə Hücumu.* Əgər  $H$  Merkl-Damqord quruluşlu heş funksiyasıdırsa,  $H(M)$  heş dəyəri və  $M$  mesajının uzunluğu ( $\text{len}(M)$ ) məlum olduqda, hücumçu orijinal  $M$  mesajını bilmədən  $H(M \parallel \text{pad} \parallel M')$  dəyərini sərbəst hesablaya bilər (Katz and Lindell, 2020).

### Hücumun iş prinsipi:

- $H(M)$  dəyəri əslində iterativ prosesin son vəziyyətini ( $h_k$  aralıq dəyəri) təmsil edir.
- Hücumçu bu  $h_k$  dəyərini sıxışdırma funksiyasının yeni "başlanğıc vəziyyəti" (IV) kimi istifadə edir.
- Orijinal mesajın sonuna əlavə etdiyi  $M'$  bloklarını bu vəziyyətdən başlayaraq emal edir və yeni keçərli heş dəyəri əldə edir.

**Nümunə 6.2** (MAC Sistemlərinə Təsir). *Tutaq ki, server mesajın həqiqiliyini yoxlamaq üçün  $H(K \parallel M)$  strukturundan istifadə edir ( $K$  - gizli açar). Hücumçu açarı bilmədən saxta bir  $M'$  hissəsini mesaja əlavə edib, onun üçün keçərli olan  $H(K \parallel M \parallel \text{pad} \parallel M')$  heş dəyərini hesablaya bilər.*

Bu tip hücumlardan qorunmaq üçün Merkl-Damqord əsaslı funksiyalarda sadə  $H(K \parallel M)$  strukturu yerinə mütləq **HMAC** (Hash-based Message Authentication Code) mexanizmi istifadə olunmalıdır (Stinson and Paterson, 2018).

## 7 Süngər (Sponge) Quruluşu

### 7.1 Süngər Konstruksiyasının İş Prinsipi

Süngər quruluşu (sponge construction) müasir **SHA-3 (Keccak)** heş funksiyasının əsasını təşkil edən innovativ bir arxitektura (Bertoni et al., 2007). Bu quruluş klassik Merkl-Damqord modelindən fərqli olaraq, uzunluq genişləndirmə hücumlarına qarşı daxili (təbii) davamlılığa malikdir.

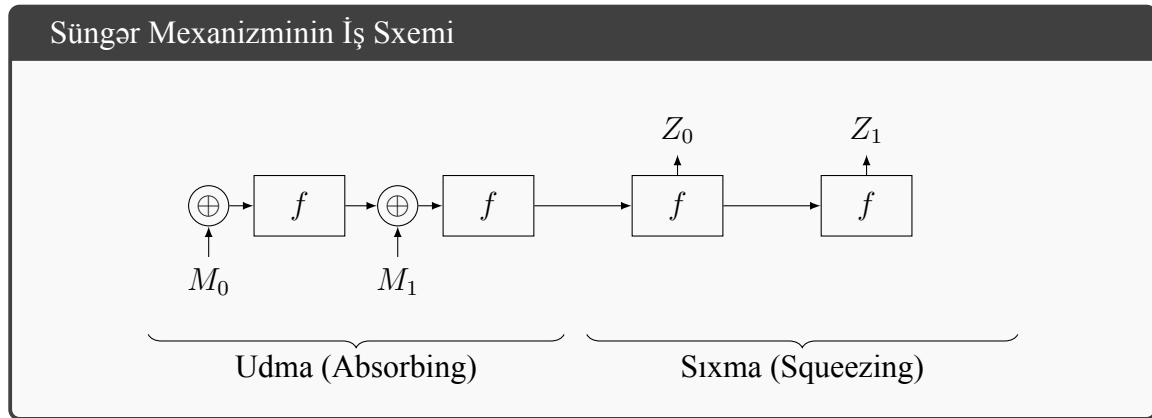


Figure 2: Süngər quruluşu: Məlumatın udulması və nəticənin sıxılıb çıxarılması

Süngər quruluşu iki əsas mərhələdən ibarətdir (Bertoni et al., 2007):

- **Udma (Absorbing):** Giriş mesaj blokları daxili vəziyyətin bir hissəsi ilə XOR əməliyyatına daxil edilir və permutasiya tətbiq olunur.
- **Sıxma (Squeezing):** Daxili vəziyyətdən ixtiyari uzunluqda çıxış (heş) dəyəri əldə edilir.

### 7.2 Süngər Quruluşunun Parametrləri

Süngər quruluşunun təhlükəsizliyi və səmərəliliyi daxili vəziyyətin ( $b$  bit) bölünməsi ilə təyin olunur (Bertoni et al., 2007):

1. **Sürət parametri ( $r$  - rate):** Hər addımda emal olunan giriş və ya hasil olunan çıxış bitlərinin sayıdır.  $r$  nə qədər böyük olsa, sürət bir o qədər yüksək olar.
2. **Təhlükəsizlik parametri ( $c$  - capacity):**  $c = b - r$  düsturu ilə hesablanır. Bu hissə birbaşa giriş-çıxış əməliyyatlarına məruz qalmır və alqoritmin kriptografik dayanıqlılığını (məsələn, toqquşma dayanıqlılığını) təmin edir.
3.  **$f$  Permutasiyası:**  $b$  bitlik daxili vəziyyəti qarışdırır və yayılmanı təmin edən təkrarlanan funksiyadır.

Süngər quruluşunda toqquşma dayanıqlılığı  $2^{c/2}$  səviyyəsindədir. Bu,  $c$  parametrinin (təhlükəsizlik ehtiyatı) düzgün seçilməsinin nə qədər kritik olduğunu göstərir.

### 7.3 Udma (Absorbing) Mərhələsi

Udma mərhələsində ixtiyari uzunluqlu giriş mesajı daxili vəziyyətə (state) integrasiya olunur (Bertoni et al., 2007):

1. Giriş mesajı  $r$ -bitlik bloklara bölünür:  $M = M_0, M_1, \dots, M_{k-1}$ .
2. Hər bir  $M_i$  bloku üçün aşağıdakı ardıcılıq icra edilir:

$$\begin{aligned} \text{state}[0..r-1] &\leftarrow \text{state}[0..r-1] \oplus M_i \\ \text{state} &\leftarrow f(\text{state}) \end{aligned}$$

Burada  $f$  permutasiyası daxili vəziyyəti tamamilə qarışdıraraq növbəti blok üçün hazırlayır.

### 7.4 Sıxma (Squeezing) Mərhələsi

Sıxma mərhələsində süngər daxili vəziyyətdən tələb olunan uzunluqda çıxış (heş) dəyərini hasil edir (Bertoni et al., 2007):

1. Süngər quruluşu mahiyyəti etibarilə ixtiyari uzunluqda çıxış hasil etməyə imkan verir.
2. Hər  $f$  permutasiyası tətbiqindən sonra daxili vəziyyətin ilk  $r$  biti çıxış kimi götürülür.
3. Tələb olunan heş uzunluğu əldə edilənə qədər proses (permutasiya və çıxış götürmə) davam edir.

**Nümunə 7.1** (SHA-3-256 Standartının Parametrləri). *SHA-3 ailəsinin 256-bitlik variantı üçün texniki konfigurasiya aşağıdakı kimidir:*

- **Daxili vəziyyət ( $b$ ):** 1600 bit.
- **Bit sürəti ( $r$ ):** 1088 bit (136 bayt).
- **Təhlükəsizlik ehtiyatı ( $c$ ):** 512 bit ( $b - r$ ).
- **Çıxış uzunluğu:** Sabit 256 bit.

**Qeyd:** "Sonsuz" uzunluqlu çıxış imkanı (XOF - Extendable-Output Functions) SHA-3 standartında xüsusi olaraq SHAKE128 və SHAKE256 funksiyaları üçün nəzərdə tutulmuşdur.

### 7.5 Merkl-Damqord və Süngər Quruluşlarının Müqayisəsi

Heş funksiyalarının dizaynında istifadə olunan bu iki fundamental yanaşma arasındakı əsas fərqlər aşağıdakı cədvəldə ümumiləşdirilmişdir:

#### Nəticə

Merkl-Damqord quruluşu uzun illər sənaye standartı olsa da, süngər quruluşu həm daha yüksək təhlükəsizlik (uzunluq genişləndirmə hücumlarına qarşı), həm də daha çox çe-  
viklik (ixtiyari uzunluqlu çıxış) təklif edərək yeni nəsil SHA-3 standartının təməlini qoy-  
muşdur.

| Xüsusiyyət                   | Merkel-Damqord                               | Süngər (Sponge)                                       |
|------------------------------|----------------------------------------------|-------------------------------------------------------|
| Daxili Vəziyyət              | $n$ bit (adətən çıxış uzunluğuna bərabərdir) | $b = r + c$ bit (çıxışdan daha böyük daxili vəziyyət) |
| Əsas Komponent               | Sıxışdırma funksiyası ( $f$ )                | Permutasiya funksiyası ( $f$ )                        |
| Prosesin İstiqaməti          | Təkyönlü (yalnız irəli emal)                 | İki mərhələli (udma və sıxma)                         |
| Çıxış Uzunluğu               | Sabit (alqoritmin dizaynı ilə təyin olunur)  | Dəyişkən (XOF – ixtiyari uzunluqlu çıxış imkanı)      |
| Uzunluq Genişləndirmə Hücumu | Həssas (əlavə qorunma tələb edir)            | Davamlı (dizayn etibarilə qorunur)                    |
| Nümunələr                    | MD5, SHA-1, SHA-2                            | SHA-3 (Keccak), SHAKE                                 |

Table 3: Merkl-Damqord və süngər konstruksiyalarının müqayisəli təhlili

## 8 Heş Funksiyalarının Praktiki Tətbiqləri

### 8.1 Parolların Təhlükəsiz Saxlanması

Heş funksiyalarının ən kritik tətbiqlərindən biri istifadəçi parollarının verilənlər bazasında açıq şəkildə deyil, qeyri-oxunacaq formatda saxlanmasıdır (Ferguson et al., 2010).

**Nümunə 8.1** (Parolun Heşlənməsi Prosesi). *İstifadəçi "parol123" şifrəsini təyin etdikdə, sistem onu birbaşa saxlamır:*

$$H(\text{parol123}) = 0x3F2A8B7C...$$

*Verilənlər bazasında yalnız bu nəticə (digest) saxlanılır. Avtorizasiya zamanı daxil edilən simvollar yenidən heşlənilir və bazadakı qeydlə müqayisə edilir.*

Parol təhlükəsizliyini artırmaq üçün iki əsas mexanizmdən istifadə olunur:

- **Duz (Salt):** Hər bir istifadəçi üçün yaradılan unikal təsadüfi dəyərdir. Parola əlavə edilərək heşlənilir və bu, "Rainbow table" (əvvəlcədən hesablanmış heş cədvəlləri) hücumlarını səmərəsiz edir (Stinson and Paterson, 2018).
- **Açar Uzatma (Key Stretching):** PBKDF2, bcrypt, scrypt və ya Argon2 kimi alqoritmlər vasitəsilə heşləmə prosesi minlərlə dəfə təkrarlanır. Bu, tam axtarış (brute-force) hücumlarını hesablama baxımından hədsiz dərəcədə bahalı edir (Ferguson et al., 2010).

### 8.2 Məlumat Bütövlüyünün Yoxlanması (Data Integrity)

Heş funksiyaları rəqəmsal obyektlərin "barmaq izi" kimi çıxış edərək onların ötürülmə və ya saxlanma zamanı dəyişdirilmədiyini sübut etmək üçün istifadə olunur (Stinson and Paterson, 2018).

**Nümunə 8.2** (Fayl Bütövlüyünün Yoxlanması). *Program təminatı istehsalçıları (məsələn, Linux distributivləri) faylın yanında onun SHA-256 heş dəyərini dərc edirlər. İstifadəçi endirdiyi faylın heşini hesablamaqla aşağıdakıları yoxlaya bilər:*

- Fayl yükləmə zamanı texniki xəta səbəbindən zədələnməyib.
- Fayl zərərli tərəf tərəfindən modifikasiya edilməyib.

Heş uyğunluğu yalnız o halda bütövlük zəmanəti verir ki, etalon heş dəyəri **etibarlı və autentik** mənbədən götürülsün. Heş funksiyası özlüyündə müəlliflik (authenticity) sübutu deyil, yalnız dəyişməzlik (integrity) indikatorudur.

### 8.3 Rəqəmsal İmzalar

Rəqəmsal imza sxemlərində (məsələn, RSA və ya ECDSA) böyük həcmli məlumatları birbaşa imzalamaq hesablama baxımından səmərəsizdir. Bunun əvəzinə, məlumatın sabit uzunluqlu heş dəyəri imzalanır (Katz and Lindell, 2020).

**Nümunə 8.3** (Heşləmə və İmzalama Prosesi). Proses aşağıdakı addımlardan ibarətdir:

1. **Heşləmə:**  $h = H(M)$  — mesajın unikal "barmaq izi" hesablanır.
2. **İmzalama:**  $\sigma = \text{Sign}_{sk}(h)$  — heş dəyəri göndəricinin gizli açarı ( $sk$ ) ilə imzalanır.
3. **Ötürmə:** Orijinal mesaj və imza  $(M, \sigma)$  birlikdə göndərilir.
4. **Verifikasiya:** Qəbul edən tərəf  $h' = H(M)$  hesablayır və açıq açar ( $pk$ ) vasitəsilə  $\text{Verify}_{pk}(h', \sigma)$  funksiyasını icra edərək imzanın doğruluğunu yoxlayır.

### 8.4 Merkle Ağacları və Blokçeyn Texnologiyası

Merkle ağacları (və ya heş ağacları) böyük verilənlər toplusunun bütövlüyünü tək bir "kök heş" (root hash) vasitəsilə səmərəli şəkildə təmin etmək üçün istifadə olunur (Antonopoulos, 2017).

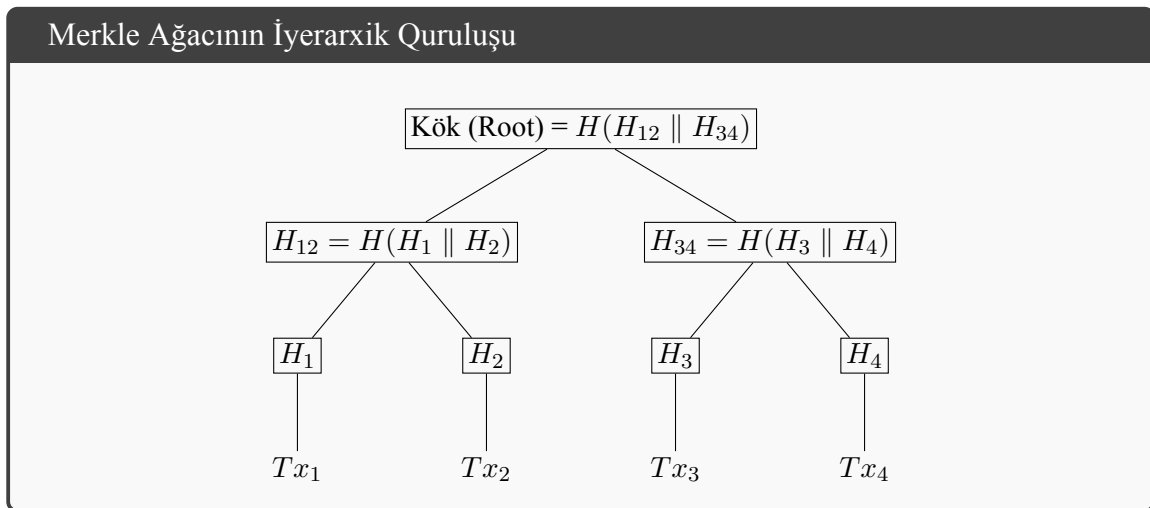


Figure 3: Tranzaksiyaların Merkle ağacı vasitəsilə qruplaşdırılması

- **Blokçeyn tətbiqi:** Bitcoin və digər kriptovalyutalarda hər blokda ki yüzrlə əməliyyat (transaction) Merkle ağacı ilə tək bir kök heşdə birləşdirilir. Bu kök heş blokun başlığında (header) saxlanılır (Antonopoulos, 2017).

- **Səmərəlilik:** Merkle ağacı bütün məlumatı yükləmədən konkret bir əməliyyatın (məsələn,  $Tx_3$ ) blok daxilində mövcudluğunu loqarifmik zaman ərzində sübut etməyə imkan verir.

Merkle ağacında hər hansı bir tranzaksiyanın bir biti belə dəyişdirilsə, bu dəyişiklik zəncirvari şəkildə kök heşə qədər təsir edəcək və bütövlüyün pozulduğunu dərhal büruzə verəcəkdir.

## 8.5 Açar Törətmə Funksiyaları (KDF)

Açar törətmə funksiyaları (Key Derivation Functions - KDF) parollar, daxil edilən entropiya və ya digər ilkin materiallardan yüksək keyfiyyətli kriptografik açarlar yaratmaq üçün istifadə olunur. Bu funksiyalar zəif və ya qeyri-bərabər paylanmış daxilolmaları kriptografik protokollar üçün uyğun olan güclü açarlara çevirir.

**Nümunə 8.4** (HKDF - HMAC-əsaslı KDF). *HKDF standartı müasir sistemlərdə geniş istifadə olunur və iki əsas mərhələdən ibarətdir:*

1. **Çıxarma (Extract):**  $PRK = HMAC_{salt}(IKM)$

- Bu mərhələdə giriş materialından (IKM - Input Keying Material) istifadə edilərək sabit uzunluqlu psevdotəsadüfi açar (PRK - Pseudorandom Key) çıxarılır.

2. **Genişləndirmə (Expand):**  $K_i = HMAC_{PRK}(K_{i-1} \parallel info \parallel i)$

- Əldə edilmiş PRK vasitəsilə konkret tətbiq sahəsi üçün lazım olan bir və ya bir neçə kriptografik açar törədilir. info parametri eyni materialdan fərqli məqsədlər üçün müxtəlif açarların alınmasını təmin edir.

## 8.6 HMAC və Mesaj Autentifikasiyası

HMAC (Hash-based Message Authentication Code) gizli açar və kriptografik heş funksiyasının kombinasiyası əsasında mesajın həm bütövlüyünü (integrity), həm də autentifikasiyasını (authenticity) təmin edən mexanizmdir (Stinson and Paterson, 2018).

**Tərif 8.1** (HMAC-ın Riyazi Konstruksiyası). *HMAC algoritmi daxili və xarici heşləmə mərhələlərindən ibarət olub aşağıdakı düsturla təyin edilir (Stinson and Paterson, 2018):*

$$HMAC_K(m) = H((K \oplus opad) \parallel H((K \oplus ipad) \parallel m))$$

Burada parametrlərin mənası aşağıdakı kimidir:

- **H:** İstifadə olunan kriptografik heş funksiyası (məsələn, SHA-256).
- **K:** Göndərən və qəbul edən tərəfə məlum olan gizli açar.
- **ipad:** Daxili doldurma sabiti (inner padding, 0x36 baytının blok ölçüsü qədər təkrarı).
- **opad:** Xarici doldurma sabiti (outer padding, 0x5C baytının blok ölçüsü qədər təkrarı).

**HMAC-ın Əsas Üstünlükləri (Stinson and Paterson, 2018):**

- **Hücumlara Davamlılıq:** Merkl-Damqord quruluşlu heş funksiyalarının ən böyük zəifliyi olan uzunluq genişləndirmə hücumlarına (*length extension attacks*) qarşı tam qorumaya malikdir.
- **Yüksək Təhlükəsizlik:** Sadə  $H(K \parallel M)$  strukturundan fərqli olaraq, HMAC-da toqquşma (collision) hücumlarının tətbiqi praktiki olaraq nəticəsizdir.
- **Müasir Standartlar:** Köhnəmiş HMAC-MD5 və ya HMAC-SHA1 əvəzinə, müasir tətbiqlərdə HMAC-SHA-256 və ya HMAC-SHA-3 istifadəsi tövsiyə olunur.
- **Geniş Tətbiq Sahəsi:** TLS, IPsec, SSH və bir çox digər şəbəkə təhlükəsizliyi protokollarında əsas autentifikasiya vasitəsidir.

#### Niyə sadə heşləmə kifayət deyil?

Xatırladaq ki, sadə heş funksiyası ( $H(M)$ ) açarsız işləyir və yalnız mesajın dəyişdirilmədiyini göstərir. Lakin hücumçu həm mesajı, həm də heşi eyni vaxtda dəyişə bilər. HMAC gizli açardan istifadə etdiyi üçün hücumçunun saxta imza (MAC) yaratması qeyri-mümkündür.

## 9 Nümunə Məsələlər və Çalışmalar

**Çalışma 9.1.** 128-bit çıxışlı bir heş funksiyası üçün ön görüntü (*pre-image*) tapmaq mürəkkəbliyi nədir? Toqquşma (*collision*) tapmaq mürəkkəbliyi nədir?

**Çalışma 9.2.** Ad günü paradoksuna əsasən, 256-bit heş funksiyasında 0.5 (50%) ehtimalla toqquşma tapmaq üçün təxminən neçə heş dəyəri hesablamaq lazımdır?

**Çalışma 9.3.** Merkl-Damqord quruluşlu heş funksiyasının uzunluq genişləndirmə hücumuna (*length extension attack*) qarşı həssas olmasının fundamental səbəbini izah edin.

**Çalışma 9.4.** SHA-3 standartının süngər quruluşu Merkl-Damqord quruluşundan texniki olaraq nə ilə fərqlənir və hansı üstünlüklərə malikdir?

**Çalışma 9.5.** Server tərəfində istifadəçi parollarının təhlükəsizliyini təmin etmək və "Rainbow table" hücumlarının qarşısını almaq üçün hansı mexanizmlər tətbiq edilməlidir?

**Çalışma 9.6.** HMAC konstruksiyaşının sadə  $H(K \parallel M)$  strukturuna nəzərən əsas təhlükəsizlik üstünlüyü nədir?

**Çalışma 9.7.** MD5 heş funksiyasında toqquşmaların praktik olaraq tapılmasının kriptografik sistemlər üçün nəticələri nələrdir?

## 10 Çalışmaların Həlli

1. **Mürəkkəblik:** Ön görüntü tapmaq mürəkkəbliyi tam axtarışla  $2^{128}$  əməliyyat təşkil edir. Toqquşma tapmaq mürəkkəbliyi isə ad günü paradoksuna əsasən  $2^{n/2}$ , yəni  $2^{64}$  əməliyyatdır.

2. **Hesablama:**  $q \approx 1.177 \cdot 2^{n/2}$  düsturuna əsasən,  $n = 256$  olduqda:

$$q \approx 1.177 \cdot 2^{128} \approx 1.177 \cdot 3.4 \times 10^{38} \approx 4.0 \times 10^{38}$$

Bu sayda heş dəyəri hesablandıqda toqquşma ehtimalı 50%-ə çatır.

3. **Həssaslıq:** Merkl-Damqord quruluşunda yekun heş dəyəri  $H(M)$  sıxışdırma funksiyasının daxili vəziyyətinin (state) son nəticəsidir. Hücumçu bu dəyəri yeni IV kimi istifadə edərək, mesajın daxilini bilmədən ona əlavə bloklar ( $M'$ ) birləşdirə və yeni keçərli heş dəyəri hesablaya bilər.
4. **Fərqlər:** Süngər quruluşu daxili vəziyyətin çıxışdan böyük olması ( $b = r + c$ ) və udma/sıxma mərhələləri ilə fərqlənir. Üstünlüyü uzunluq genişləndirmə hücumlarına qarşı daxili davamlılığı və dəyişkən uzunluqlu çıxış (XOF) təmin etməsidir.
5. **Tədbirlər:** "Rainbow table" hücumlarını səmərəsiz etmək üçün hər istifadəçiyə unikal **duz (salt)** təyin edilməlidir. Əlavə olaraq, brute-force hücumlarını çətinləşdirmək üçün *bcrypt* və ya *Argon2* kimi "yavaş" heş funksiyaları seçilməlidir.
6. **HMAC Üstünlüyü:** HMAC konstruksiyası uzunluq genişləndirmə hücumlarına qarşı tam qorunma təmin edir. Sadə  $H(K \parallel M)$  strukturu isə bu hücumla qarşı tamamilə müdafiəsizdir.
7. **Bütövlük:** Heş dəyərinin dəyişməz qalması məlumatın modifikasiya olunmadığını göstərir. Lavina effekti (avalanche effect) sayəsində mesajda edilən minimal dəyişiklik belə heş dəyərinin tamamilə fərqli olmasına gətirib çıxarır.
8. **MD5 Nəticələri:** MD5-də toqquşmaların tapılması eyni heşə malik fərqli faylların yaradılmasına imkan verir. Bu, rəqəmsal imzaların saxtalaşdırılmasına və autentifikasiya sistemlərinin kütləvi şəkildə pozulmasına yol açdığı üçün MD5 artıq istifadə edilməməlidir.

## 11 Xülasə

Bu müəhazirədə kriptografik heş funksiyalarının quruluşu və tətbiqi sahəsində aşağıdakı əsas anlayışlar öyrənilmişdir:

- **Heş funksiyaları:** İxtiyari uzunluqlu məlumatı sabit uzunluqlu çıxışa (digest) çevirən birtərəfli funksiyalardır.
- **Təhlükəsizlik xüsusiyyətləri:**
  - **Ön görüntü (Pre-image) dayanıqlılığı:** Verilmiş  $y$  heş dəyəri üçün  $H(x) = y$  şərtini ödəyən  $x$  girişini tapmağın çətinliyi ( $2^n$  mürəkkəblik).
  - **İkinci ön görüntü dayanıqlılığı:** Verilmiş  $x_1$  girişi üçün  $H(x_1) = H(x_2)$  şərtini ödəyən fərqli  $x_2$  tapmağın çətinliyi ( $2^n$  mürəkkəblik).

- **Toqquşma (Collision) dayanıqlılığı:** Eyni heş dəyərinə malik hər hansı iki fərqli  $x_1, x_2$  cütünü tapmağın çətinliyi ( $2^{n/2}$  mürəkkəblilik).
- **Ad günü paradoksu:** Ehtimal nəzəriyyəsinə əsasən,  $N$  mümkün çıxış arasında toqquşma ehtimalı  $q \approx 1.177\sqrt{N}$  sınaqdan sonra 0.5-ə çatır. Bu, heş funksiyalarında toqquşma mürəkkəbliyini  $2^{n/2}$  səviyyəsinə endirir.
- **Merkel-Damqord quruluşu:** MD5, SHA-1 və SHA-2 funksiyalarının əsasını təşkil edən iterativ modeldir. Əsas zəifliyi **uzunluq genişləndirmə hücumuna** (length extension attack) qarşı həssas olmasıdır.
- **Süngər (Sponge) quruluşu:** SHA-3 (Keccak) standartının təməlidir. Udma (*absorb*) və sıxma (*squeeze*) mərhələlərindən ibarət olub, uzunluq genişləndirmə hücumlarına qarşı təbii davamlılığa malikdir.
- **Praktik tətbiqlər:** Parolların "duz" (*salt*) ilə saxlanması, rəqəmsal imzalar, fayl bütövlüyünün yoxlanması, blokçeyn sistemlərində Merkle ağacları və mesaj autentifikasiyası üçün HMAC strukturu.

**Nəticə:** Müasir kriptografiyada heş funksiyalarının təhlükəsizliyi həm riyazi xüsusiyyətlərdən, həm də istifadə olunan konstruksiyadan asılıdır. SHA-2 hələ də geniş istifadə olunsada, süngər quruluşlu SHA-3 daha çevik və hücumlara qarşı daha dayanıqlı alternativ təklif edir.

## References

- A. M. Antonopoulos. *Mastering Bitcoin: Programming the Open Blockchain*. O'Reilly Media, Sebastopol, CA, 2nd edition, 2017. ISBN: 978-1491954386.
- G. Bertoni, J. Daemen, M. Peeters, and G. V. Assche. Sponge functions. *ECRYPT Hash Function Workshop*, 2007. Available: <https://keccak.team/files/SpongeFunctions.pdf>.
- I. Damgård. A design principle for hash functions. *Advances in Cryptology - CRYPTO '89*, 435: 416–427, 1989. doi: 10.1007/0-387-34805-0\_39.
- N. Ferguson, B. Schneier, and T. Kohno. *Cryptography Engineering: Design Principles and Practical Applications*. Wiley, Indianapolis, 2010. ISBN: 978-0470474242.
- J. Katz and Y. Lindell. *Introduction to Modern Cryptography*. CRC Press, Boca Raton, 3rd edition, 2020. ISBN: 978-0815354369.
- R. C. Merkle. One way hash functions and des. *Advances in Cryptology - CRYPTO '89*, 435: 428–446, 1989. doi: 10.1007/0-387-34805-0\_40.
- C. Paar and J. Pelzl. *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer, Berlin, 2010. ISBN: 978-3642041006.
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.
- X. Wang and H. Yu. How to break md5 and other hash functions. *Advances in Cryptology - EUROCRYPT 2005*, 3494:19–35, 2005. doi: 10.1007/11426639\_2.